HELLA company 업무관리사이트 — Firestore 보안 규칙 설계서 v1

---

0. 문서 목적

이 문서는 실제 개발 직전에 적용되는 **Firestore 보안 규칙의 최종 기준 설계서**다.

목표: - 권한 완전 분리 - 상태 기반 제어 - 데이터 무결성 보장 - 클라이언트 조작 차단

---

1. 최상위 보안 원칙

1. 로그인되지 않은 모든 접근 차단
2. Firestore Rules = 최종 권한 판정자
3. 상태 전이는 허용된 흐름만 통과
4. 민감 데이터는 최소 권한 원칙 적용
5. 감사 로그는 절대 수정/삭제 금지
6. NFC/장비는 트랜잭션 기반 처리
7. 클라이언트는 “입력만”, 상태 결정은 서버

---

2. 역할 체계

역할	설명	권한 수준
EMPLOYEE	일반 사원	본인 데이터만
LEADER	팀장	팀 범위 일부
ADMIN	관리자	전체 운영
SUPER_ADMIN	최고관리자	시스템 제어

---

3. 공통 접근 조건

- 인증 필수
- 사용자 활성 상태 필수
- 역할 기반 접근
- 본인 여부 체크

---

4. 컬렉션별 권한 설계

4-1. users

읽기 - 본인 - ADMIN 이상

생성 - ADMIN 이상

수정 - 본인: 프로필 일부만 - ADMIN: 전체 수정

금지 - role 변경 (본인) - isActive 변경 (본인)

삭제 - 금지 (soft delete)

4-2. business_categories / subcategories

읽기 - 로그인 사용자

쓰기 - ADMIN 이상

삭제 - 금지 (비활성 처리)

4-3. manuals

읽기 - 로그인 사용자

쓰기 - ADMIN 이상

삭제 - 금지

4-4. schedules

읽기 - ADMIN: 전체 - EMPLOYEE: 본인 workerIds 포함 시

쓰기 - ADMIN만

삭제 - 금지

4-5. schedule_workers

읽기 - ADMIN - 본인 workerId

생성 - ADMIN

수정 - 사원: 시작/종료만 - 관리자: 전체

금지 - workerId 변경 - scheduleId 변경

4-6. schedule_closings

읽기 - 본인 - 관리자

생성 - 본인 배정 일정만

수정 - 관리자만

삭제 - 금지

조건 - 시작/종료 없이 생성 금지

4-7. schedule_photos

읽기 - 업로더 - 관리자

생성 - 본인

수정 - 제한적 (메모 정도)

삭제 - 업로더 또는 관리자

금지 - scheduleId 변경 - storagePath 변경

4-8. regular_cleaning_sites

읽기 - 전체 사용자

쓰기 - ADMIN

삭제 - 금지

4-9. regular_cleaning_attendance

읽기 - 본인 - 관리자

생성 - ADMIN

수정 - 본인: 시작/종료 - 관리자: 승인

4-10. equipments

읽기 - 로그인 사용자

쓰기 - ADMIN

삭제 - 금지

상태 - IN / OUT / DISABLED

4-11. nfc_tag_mappings

읽기 - ADMIN

쓰기 - ADMIN

삭제 - 금지

4-12. equipment_logs

읽기 - 본인 - ADMIN

쓰기 - ❌ 금지 (Functions 전용)

수정/삭제 - 금지

4-13. audit_logs

읽기 - ADMIN

쓰기 - Functions 또는 관리자

수정/삭제 - ❌ 금지

4-14. download_logs

읽기 - ADMIN

쓰기 - 관리자 / Functions

수정/삭제 - 금지

4-15. settings

읽기 - ADMIN

수정 - ADMIN

생성 - SUPER_ADMIN

삭제 - 금지

---

5. 상태 전이 규칙

schedules

- PLANNED → IN_PROGRESS → COMPLETED
- CANCELLED

schedule_workers

- ASSIGNED → STARTED → ENDED → CLOSED

equipments

- IN → OUT
- OUT → IN
- IN → DISABLED

---

6. Functions 필수 영역

다음은 반드시 서버에서 처리

1. 장비 반출/반입
2. equipment_logs 생성
3. audit_logs 기록
4. 일정 생성 시 worker 자동 생성
5. 참여 인정 계산
6. 상태 동기화

---

7. 금지 항목

- 클라이언트 장비 상태 직접 수정
- 클라이언트 로그 생성
- role 변경
- 상태 강제 변경
- 교차 문서 조작

---

8. Storage Rules 방향

경로 - schedule_photos/{scheduleId}/{uid} - manuals/{id} - logos/

권한 - 사진: 업로더 + 관리자 - 메뉴얼: 관리자 업로드 / 사용자 조회 - 로고: 관리자

---

9. 테스트 체크리스트

- 비로그인 접근 차단
- 타 사용자 데이터 접근 차단
- role 변경 차단
- 장비 로그 직접 생성 차단
- 일정 무단 수정 차단
- 마감 재수정 차단
- 비활성 사용자 차단

---

10. 최종 결론

이 구조의 핵심은 단순하다.

- “사원은 입력만 한다”
- “상태는 서버가 결정한다”
- “로그는 절대 수정되지 않는다”

이 3가지가 깨지면 시스템이 무너진다.

이 설계는 그걸 막기 위한 최소 조건이다.